Northwind Dental Ltd

Google Workspace review: summary and action plan

ORGANISATION	PRIMARY DOMAIN	CUSTOMER ID
Northwind Dental Ltd	**northwinddental.example**	**C01abc2de**
REVIEW DATE	REVIEWED BY	REPORT VERSION
19/10/2026	**it.support@northwinddental.example**	**Tool v1.5.0**

1. Executive summary



Red

60 checks assessed: 8 pass, 38 warning, 14 fail

25
Active users
1 suspended

80%
2SV enrolled
20 of 25 users

3
Super admins
Recommended 2 to 4

26
Licences assigned
Business Standard, Business Plus

4
Third-party apps
Granted by users

6
Managed devices
1 not encrypted

4
Alerts (90 days)
2 not closed

2
Unused licensed features
1 more partly used

41%
CIS v1.4.0
28 of 69 assessed controls met

38%
CISA SCuBA
40 of 104 assessed controls met

Overview

Northwind Dental Ltd's Google Workspace was reviewed on 19/10/2026 against 72 checks across 13 areas. The weighted score is 39% (Red). Of the checks assessed, 14 failed, 38 need attention and 8 passed. 11 high-severity issues should be addressed first. Estimated remediation effort for all failed and warning items is about 84.0 hours (11.2 days).

The organisation already has licences for features that are not being used. Not used: 2. Partly used: 1. Setting these up is estimated at 4.5 days (see Opportunities).

Against the published benchmarks the organisation meets: CIS v1.4.0 41% (28 of 69 assessed controls, 13 to check manually); CISA SCuBA 38% (40 of 104 assessed controls, 15 to check manually) (see Benchmarks).

What needs doing

Must do
11 items
Start within 2 weeks
About 3.5 days

Should do
6 items
Within 3 months
About 2 days

Could do
35 items
Within 6 months
About 7 days

Use what you already pay for
3 features
After the fixes above
About 4.5 days

11 must-do items should be started within two weeks (about 3.5 days), 6 should-do items within three months (about 2 days) and 35 could-do items within six months (about 7 days). In total this is about 12.5 days of engineer time, or roughly 7 weeks at 2 engineer days a week. 6 of the must-do and should-do items are quick wins of an hour or less. A further 3 licensed features you already pay for could be put to use (about 4.5 days). See the action plan.

Top priorities

When	What good looks like	What we found	Effort
Must do	SPF authorises Google and ends with -all or ~all	1 of 2 mail domains has an SPF problem.	1 hour
Must do	2-Step Verification is enforced for all users	2-Step Verification is enforced for the organisation. But 2-Step Verification is not enforced in 1 override: OU /Staff/Locums.	4 hours
Must do	Spoofing and authentication protections are on	Some spoofing protections are off for the whole organisation. Off: unauthenticated email.	1 hour
Must do	Recent high-severity alerts have been dealt with	1 high-severity alert is open in the last 90 days (4 alerts in total).	2 hours
Must do	Compromised mobile devices are blocked	1 device is reported as compromised. Compromised devices are not blocked for the whole organisation.	2 hours
Must do	Users cannot grant unreviewed third-party apps access to company data	Users can grant any unconfigured third-party app access to their data for the whole organisation. Access level: allow any app.	3 hours
Must do	DKIM signing is set up with a 2048-bit key	1 of 2 mail domains is missing DKIM or uses a short key.	1 hour
Must do	All active users are enrolled in 2-Step Verification	80% of active users are enrolled; 5 users are not enrolled.	4 hours
Must do	Automatic forwarding is turned off	Automatic forwarding is off for the organisation. But users can automatically forward mail to any address in 1 override: OU /Staff/Clinicians.	1 hour
Must do	No accounts show signs of compromise	2 accounts with 2 security sign-in events in the last 30 days.	2 hours

Results by area

Area	RAG	Fail	Warning	Pass	Info or manual
Applications	Red	1	2	1	1
Calendar, Chat and Meet	Amber	0	4	0	0
Devices	Red	1	3	0	1
Drive and Docs	Amber	0	6	1	1
Email DNS	Red	3	2	0	1
Gmail	Red	3	6	3	0
Groups	Amber	0	2	0	2
Identity and access	Red	3	7	2	2
Licensing	Amber	0	2	0	1
Privileged access	Amber	0	4	1	1
Security operations	Red	3	0	0	2

Licensed but not used

Status	Feature	Licensed users	Current use
Not used	Data regions	24	No data region is set, so data can be stored in any Google region.
Not used	Google Vault retention and eDiscovery	10	No Vault activity was logged in the last 180 days. Retention rules cannot be read through the API, so confirm in Vault whether default retention is set.
Partly used	Passkeys and security keys	24	7 of 24 users have a passkey or security key (29.2%).

2. Action plan

This plan turns the findings into work, grouped by what it protects and ordered by urgency. Must do items are serious gaps to fix first, should do items are important improvements, and could do items are good practice. Effort is the estimated engineer time to make each change; it is for planning only and does not include time for agreeing changes, telling staff or testing with Northwind Dental Ltd.

Must do
11 items
Start within 2 weeks
About 3.5 days

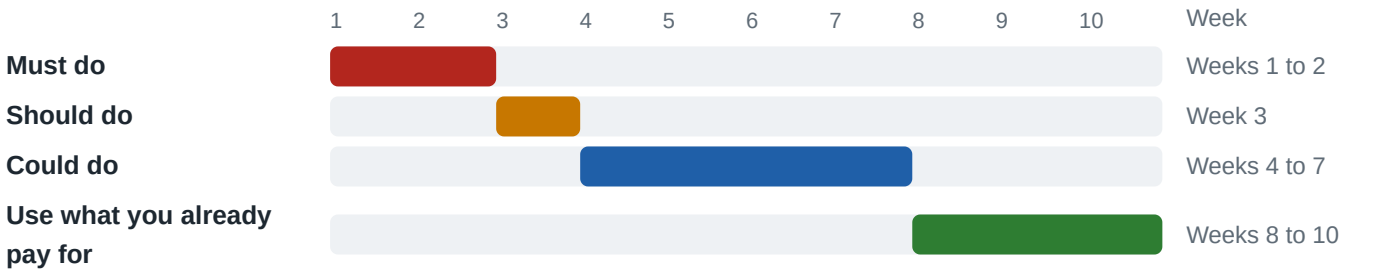
Should do
6 items
Within 3 months
About 2 days

Could do
35 items
Within 6 months
About 7 days

Use what you already pay for
3 features
After the fixes above
About 4.5 days

11 must-do items should be started within two weeks (about 3.5 days), 6 should-do items within three months (about 2 days) and 35 could-do items within six months (about 7 days). In total this is about 12.5 days of engineer time, or roughly 7 weeks at 2 engineer days a week. 6 of the must-do and should-do items are quick wins of an hour or less. A further 3 licensed features you already pay for could be put to use (about 4.5 days).

Indicative timeline



Based on 2 engineer days a week. With more engineer time the phases can overlap and finish sooner. Some licensed features overlap with the fixes, so that work may take less time once the earlier phases are done.

1 Must do: start within 2 weeks

Serious gaps that leave the business open to attack, data loss or disruption today. These should be fixed first.

Stop others sending email as you

About 4 hours

Why it matters. SPF, DKIM and DMARC records prove your email is genuine. Without them, criminals can send convincing emails that look as if they come from you, to your staff, customers and suppliers.

SPF authorises Google and ends with -all or ~all — 1 hour
We found: 1 of 2 mail domains has an SPF problem.

DKIM signing is set up with a 2048-bit key — 1 hour
We found: 1 of 2 mail domains is missing DKIM or uses a short key.

DMARC is enforced with reporting — 2 hours
We found: 2 of 2 domains do not enforce DMARC with reporting.

WHAT YOUR STAFF WILL NOTICE

No change for staff.

WHAT WE NEED FROM YOU

Access to your DNS provider, and a list of other services that send email for you (for example invoicing or marketing systems).

Protect sign-ins and accounts

About 1.5 days

Why it matters. Most attacks start with a stolen or guessed password. These changes make it much harder for anyone to get into a staff account, even if they have the password.

2-Step Verification is enforced for all users — 4 hours

We found: 2-Step Verification is enforced for the organisation. But 2-Step Verification is not enforced in 1 override: OU /Staff/Locums.

All active users are enrolled in 2-Step Verification — 4 hours

We found: 80% of active users are enrolled; 5 users are not enrolled.

WHAT YOUR STAFF WILL NOTICE

Staff may be asked to set up an authenticator app and could be prompted to sign in again on their devices.

WHAT WE NEED FROM YOU

Agree a date to tell staff, and confirm any shared or emergency accounts that need different treatment.

Strengthen email security

About 2 hours

Why it matters. Email is the most common way criminals reach staff, through phishing and harmful attachments. These settings block more threats and stop email being quietly forwarded outside the business.

Spoofing and authentication protections are on — 1 hour

We found: Some spoofing protections are off for the whole organisation. Off: unauthenticated email.

Automatic forwarding is turned off — 1 hour

We found: Automatic forwarding is off for the organisation. But users can automatically forward mail to any address in 1 override: OU /Staff/Clinicians.

WHAT YOUR STAFF WILL NOTICE

Little change for staff. Some suspicious messages will be held in quarantine instead of reaching inboxes.

WHAT WE NEED FROM YOU

Tell us about any automatic forwarding to outside addresses that the business relies on.

Detect and respond to threats

About 4 hours

Why it matters. Security tools only help if they are switched on, cover every device and someone acts on their alerts.

Recent high-severity alerts have been dealt with — 2 hours

We found: 1 high-severity alert is open in the last 90 days (4 alerts in total).

No accounts show signs of compromise — 2 hours

We found: 2 accounts with 2 security sign-in events in the last 30 days.

WHAT YOUR STAFF WILL NOTICE

No change for staff.

WHAT WE NEED FROM YOU

Confirm who should receive security alerts, including out of hours.

Secure laptops, desktops and phones

About 2 hours

Why it matters. Devices hold company data and are used to sign in. Managing, encrypting and updating them protects that data if a device is lost, stolen or infected.

Compromised mobile devices are blocked — 2 hours

We found: 1 device is reported as compromised. Compromised devices are not blocked for the whole organisation.

WHAT YOUR STAFF WILL NOTICE

Devices may restart for updates, and staff may be asked to enrol phones or accept new settings.

WHAT WE NEED FROM YOU

Agree a small pilot group first, then a date for everyone else.

Control connected apps

About 3 hours

Why it matters. Apps connected to your accounts can often read email and files. Reviewing them, and requiring approval for new ones, stops data being handed to unsafe apps without anyone noticing.

Users cannot grant unreviewed third-party apps access to company data — 3 hours

We found: Users can grant any unconfigured third-party app access to their data for the whole organisation. Access level: allow any app.

WHAT YOUR STAFF WILL NOTICE

Staff will need approval before connecting new apps to their work account.

WHAT WE NEED FROM YOU

Confirm which connected apps are used for business.

2 Should do: within 3 months

Important improvements that close real risks. Plan these into the next three months.

Lock down administrator access

About 2 hours

Why it matters. Administrator accounts can change or delete anything. Keeping them few in number and well protected limits the damage if one is compromised.

Super admins use security keys or passkeys — 2 hours

We found: 1 super admin is without a phishing-resistant sign-in method.

WHAT YOUR STAFF WILL NOTICE

Only IT administrators are affected.

WHAT WE NEED FROM YOU

Confirm who genuinely needs administrator access.

Stop others sending email as you

About 2 hours

Why it matters. SPF, DKIM and DMARC records prove your email is genuine. Without them, criminals can send convincing emails that look as if they come from you, to your staff, customers and suppliers.

MX records deliver mail to Gmail — 2 hours

We found: 1 domain does not deliver straight to Gmail. Other servers can be a mail filter (fine if it relays to Gmail) or a leftover from a previous provider.

WHAT YOUR STAFF WILL NOTICE

No change for staff.

WHAT WE NEED FROM YOU

Access to your DNS provider, and a list of other services that send email for you (for example invoicing or marketing systems).

Control connected apps

About 3 hours

Why it matters. Apps connected to your accounts can often read email and files. Reviewing them, and requiring approval for new ones, stops data being handed to unsafe apps without anyone noticing.

Third-party apps with access to mail, files or admin data are reviewed — 3 hours

We found: 3 third-party apps with high-impact access, granted by 6 users.

WHAT YOUR STAFF WILL NOTICE

Staff will need approval before connecting new apps to their work account.

WHAT WE NEED FROM YOU

Confirm which connected apps are used for business.

Protect sign-ins and accounts

About 3 hours

Why it matters. Most attacks start with a stolen or guessed password. These changes make it much harder for anyone to get into a staff account, even if they have the password.

The password policy requires strong passwords of at least 12 characters 3 hours

We found: The password policy falls short for the whole organisation. Minimum length 10; not enforced at next sign-in.

WHAT YOUR STAFF WILL NOTICE

Staff may be asked to set up an authenticator app and could be prompted to sign in again on their devices.

WHAT WE NEED FROM YOU

Agree a date to tell staff, and confirm any shared or emergency accounts that need different treatment.

Strengthen email security

About 1 hour

Why it matters. Email is the most common way criminals reach staff, through phishing and harmful attachments. These settings block more threats and stop email being quietly forwarded outside the business.

Attachment protections are on 1 hour

We found: Some attachment protections are off for the whole organisation. Off: anomalous attachment types.

WHAT YOUR STAFF WILL NOTICE

Little change for staff. Some suspicious messages will be held in quarantine instead of reaching inboxes.

WHAT WE NEED FROM YOU

Tell us about any automatic forwarding to outside addresses that the business relies on.

Detect and respond to threats

About 1 hour

Why it matters. Security tools only help if they are switched on, cover every device and someone acts on their alerts.

Key system alert rules are on and notify someone 1 hour

We found: 2 alert rules need attention: User granted Admin privilege (off), Leaked password (no email notifications).

WHAT YOUR STAFF WILL NOTICE

No change for staff.

WHAT WE NEED FROM YOU

Confirm who should receive security alerts, including out of hours.

3 Could do: within 6 months

Good-practice improvements that tighten security further and bring you in line with the published benchmarks. Select an item to see what we found.

Protect sign-ins and accounts

About 1.5 days

Why it matters. Most attacks start with a stolen or guessed password. These changes make it much harder for anyone to get into a staff account, even if they have the password.

Text message and phone call codes are not allowed for 2-Step Verification	3 hours
No users have weak or short passwords	2 hours
Web sessions require sign-in again within 12 hours	1 hour
Licensed users have signed in recently	2 hours
App passwords are not in use	1 hour
Users cannot skip 2-Step Verification on trusted devices	1 hour
Unmanaged accounts using company domains are taken over	1 hour

WHAT YOUR STAFF WILL NOTICE

Staff may be asked to set up an authenticator app and could be prompted to sign in again on their devices.

WHAT WE NEED FROM YOU

Agree a date to tell staff, and confirm any shared or emergency accounts that need different treatment.

Lock down administrator access

About 5 hours

Why it matters. Administrator accounts can change or delete anything. Keeping them few in number and well protected limits the damage if one is compromised.

Super admin accounts are not used for everyday email	3 hours
Super admins cannot recover their own accounts	1 hour
Admin roles are not held by suspended or inactive accounts	1 hour

WHAT YOUR STAFF WILL NOTICE
Only IT administrators are affected.

WHAT WE NEED FROM YOU
Confirm who genuinely needs administrator access.

Strengthen email security

About 1.5 days

Why it matters. Email is the most common way criminals reach staff, through phishing and harmful attachments. These settings block more threats and stop email being quietly forwarded outside the business.

Link and image protections are on	1 hour
POP and IMAP are turned off or limited	2 hours
Spam filtering is not bypassed for whole domains or IP ranges	2 hours
Users are warned before replying to external recipients	1 hour
Mail delegation is controlled	1 hour
Users cannot import mail from other accounts	1 hour

WHAT YOUR STAFF WILL NOTICE
Little change for staff. Some suspicious messages will be held in quarantine instead of reaching inboxes.

WHAT WE NEED FROM YOU
Tell us about any automatic forwarding to outside addresses that the business relies on.

Stop others sending email as you

About 1 hour

Why it matters. SPF, DKIM and DMARC records prove your email is genuine. Without them, criminals can send convincing emails that look as if they come from you, to your staff, customers and suppliers.

All domains in Google Workspace are verified	1 hour

WHAT YOUR STAFF WILL NOTICE
No change for staff.

WHAT WE NEED FROM YOU
Access to your DNS provider, and a list of other services that send email for you (for example invoicing or marketing systems).

Secure laptops, desktops and phones

About 5 hours

Why it matters. Devices hold company data and are used to sign in. Managing, encrypting and updating them protects that data if a device is lost, stolen or infected.

Devices are encrypted	2 hours
Windows 10 and unsupported ChromeOS devices are replaced	2 hours
Android security patches are recent	1 hour

WHAT YOUR STAFF WILL NOTICE
Devices may restart for updates, and staff may be asked to enrol phones or accept new settings.

WHAT WE NEED FROM YOU
Agree a small pilot group first, then a date for everyone else.

Control file sharing

About 1.5 days

Why it matters. Files shared with open links can be passed on to anyone. Tightening sharing reduces the chance of sensitive documents reaching the wrong people.

External sharing is limited and users are warned	2 hours
Files cannot be published to the web	1 hour

Access checker suggests recipients only	1 hour
Shared drives keep content inside the drive	1 hour
Drive for desktop is limited to company devices	2 hours
The Drive link security update is applied	1 hour

WHAT YOUR STAFF WILL NOTICE
Staff may need to share with named people rather than with anyone who has the link.

WHAT WE NEED FROM YOU
Agree how staff should share files with clients and suppliers.

Secure meetings, chat and groups

About 7 hours

Why it matters. Settings for who can join meetings, message your staff and create groups decide how easily outsiders get in and how easily information leaks out.

Group creation and outside access are restricted	1 hour
Groups do not accept posts or joins from anyone on the internet	2 hours
Calendars share only free/busy outside the organisation	1 hour
Chat is limited to trusted external domains	1 hour
Meet asks external people to knock and labels them	1 hour
Google Takeout is controlled	1 hour

WHAT YOUR STAFF WILL NOTICE
External guests may wait in a lobby or need an invitation to join.

WHAT WE NEED FROM YOU
Confirm which outside organisations staff need to work with.

Control connected apps

About 2 hours

Why it matters. Apps connected to your accounts can often read email and files. Reviewing them, and requiring approval for new ones, stops data being handed to unsafe apps without anyone noticing.

Only approved Marketplace apps can be installed	2 hours

WHAT YOUR STAFF WILL NOTICE
Staff will need approval before connecting new apps to their work account.

WHAT WE NEED FROM YOU
Confirm which connected apps are used for business.

Make sure licences are right

About 2 hours

Why it matters. Unused or unsuitable licences cost money every month and can leave security features out of reach.

Suspended users do not hold paid licences	1 hour
Active users have a Google Workspace licence	1 hour

WHAT YOUR STAFF WILL NOTICE
No change for staff.

WHAT WE NEED FROM YOU
Approve any licence changes.

4 Use what you already pay for

Features included in your current licences that are not set up yet. Using them adds protection or saves time at no extra licence cost.

Feature	Now	What it gives you	Effort
Data regions	Not used	Supports data residency commitments in contracts and tenders.	0.5 days

Feature	Now	What it gives you	Effort
Google Vault retention and eDiscovery	Not used	Keeps mail and files for as long as the business must, even if users delete them, and supports subject access requests and disputes.	2 days
Passkeys and security keys	Partly used	Phishing-resistant sign-in at no extra licence cost.	2 days